Plan de auditoría de la seguridad del canal digital de la Clínica Santa Lucía

Universidad Privada de Tacna · Escuela de Ingeniería de Sistemas

SI-084 · Auditoría de Sistemas · Examen práctico de Unidad II

Docente: Dr. Oscar Juan Jimenez Flores

CONFIDENCIAL · USO ACADÉMICO · Tacna, Perú

Dato	Contenido
Apellidos y nombres	Colque Ponce, Sergio
Código de estudiante	2022073503
URL del repositorio	https://github.com/srg-cp/si084-caso-clinica/tree/examen-u2
Fecha de reconocimiento y elaboración	28/10/2026
Periodo objeto de auditoría	01/01/2026 al 30/09/2026

1. Resultados del reconocimiento OWASP WSTG 4.2

Información de la entidad y conocimiento previo

La Clínica Santa Lucía S.A.C. es una IPRESS privada de nivel II-1 ubicada en Tacna. La supervisan SUSALUD y la Autoridad Nacional de Protección de Datos Personales. Cuenta con 162 trabajadores, tres de sistemas, e ingresos de S/ 18 600 000 en 2025. Su canal digital ofrece 3 850 citas mensuales, resultados para 12 400 pacientes con cuenta y recepción de 214 postulaciones con CV durante 2026. WebSur S.A.C. desarrolla, aloja y mantiene el portal desde 2021.

La comisión ejecutó exclusivamente el reconocimiento público autorizado. Los banners, comentarios y versiones en URL son indicios publicados; no acreditan software instalado ni vulnerabilidades explotables. La observación del 28/10/2026 tampoco demuestra automáticamente la configuración histórica del periodo auditado.

Prueba	Identificador WSTG	Lo observado con cifras	Declaración	¿Coincide?	Evidencia
E1	WSTG-INFO-04	Respondieron 3 aplicaciones con HTTP 200 entre 11 puertos: portal 8080, pruebas 8081 y API 8088. Pruebas anuncia copia productiva restaurada el 12/09/2026 y una cuenta de pruebas. La API anuncia api-citas 1.4.0, entorno produccion y 3 endpoints no consultados.	D1: un activo	No: 3 frente a 1.	evidencias/E1_aplicaciones.txt
E2	WSTG-INFO-02	2 versiones anunciadas: nginx/1.20.2 y PHP/7.4.3. PHP 7.4 terminó soporte el 28/11/2022. nginx 1.20 es legado, sustituida como rama estable el 24/05/2022; esa fecha de sustitución no equivale a un EOL contractual certificado.	D2: versiones vigentes	No respecto de las versiones anunciadas.	evidencias/E2_servidor.txt
E3	WSTG-INFO-03	4 Disallow en robots.txt: /admin/, /respaldos/, /resultados/ y /wp-content/plugins/wp-file-manager/. security.txt devolvió HTTP 404. Robots revela rutas y no restringe su acceso.	-	No aplica.	evidencias/E3_metarchivos.txt

Prueba	Identificador WSTG	Lo observado con cifras	Declaración	¿Coincide?	Evidencia
E4	WSTG-INFO-05	4 comentarios HTML; 3 revelan información interna: cuenta admin_pruebas, dirección interna de integración LIS y patrón ver.php?orden=NNNNN. El cuarto identifica proveedor/contacto. Contraseña inicial publicada: nacimiento ddmmaaaa. Generator: WordPress 5.8.1. No se visitó la dirección interna ni se probaron órdenes.	D8: sin datos internos	No. El patrón motiva verificar autorización, sin demostrar IDOR.	evidencias/E4_contenido.txt
E5	WSTG-INFO-08	4 recursos versionados: medicalpro 2.1.0, Contact Form 7 5.3.1, jQuery 3.4.1 y recurso wp-file-manager con ver=6.8. E4 anuncia WordPress 5.8.1 frente a 6.6 declarado. CVE-2020-25213 afecta File Manager anterior a 6.9. El parámetro es indicio, no prueba de instalación/explotación.	D3: actualización mensual	No corroborada; versiones antiguas e incompatibles con inventario. El historial mensual no se probó.	evidencias/E5_componentes.txt y E4
E6	WSTG-INFO-06	4 formularios y 4 actions HTTP. Citas solicita identidad/contacto y salud (especialidad/síntomas), usa GET y casilla acepto. Resultados pide DNI/clave; postulaciones pide identidad/correo y 1 CV; administración pide credenciales. Los 3 primeros recogen datos personales; citas pide explícitamente salud. Ninguno fue enviado.	D7: no exponen datos	No sustentada: riesgo en URL por GET; filtración efectiva no probada.	evidencias/E6_entradas.txt
E7	WSTG-CONF-04 · WSTG-CONF-05	/respaldos/ lista 4 archivos: 2 .sql.gz, 1 .csv y 1 .php.bak. /admin/ devuelve HTTP 200 desde fuera de la red declarada. No se descargaron archivos ni se intentó autenticación.	D5 · D6	No: interfaz visible y listado dentro de raíz web. HTTP 200 no acredita privilegios.	evidencias/E7_expuestos.txt
E8	WSTG-CONF-07 · WSTG-CONF-12 · WSTG-SESS-02	Faltan 4 de 4 cabeceras: HSTS, CSP, X-Frame-Options y X-Content-Type-Options. PHPSESSID carece de Secure, HttpOnly y SameSite: 3 atributos. HTTP responde sin redirección. No se consultó 443 por estar fuera de 8080-8090.	D4: cifrado y cabeceras	No respecto del HTTP y cabeceras. HTTPS 443: no determinado.	evidencias/E8_cabeceras.txt

Las ocho salidas están selladas en evidencias/SHA256SUMS.txt. E8 omite la consulta a 443 del enunciado porque ALCANCE-AUTORIZADO.md permite únicamente 127.0.0.1:8080-8090. La comisión solicitará aclaración al docente antes de ampliar ese límite; no se afirma un HTTP 000 no medido.

Ninguna de las ocho declaraciones quedó corroborada íntegramente. D1, D2, D4, D5, D6 y D8 presentan contradicciones observables; D3 ofrece versiones incompatibles con el inventario, sin demostrar el historial mensual; D7 queda sin sustento ante GET, sin probar una filtración efectiva. La comisión adoptará un enfoque sustantivo. El patrón de orden y la contraseña predecible se relacionan con el incidente del 08/09/2026 como hipótesis de acceso indebido. La explicación de caché tampoco está demostrada; ambas posibilidades se investigarán con pruebas autorizadas y registros históricos.

2. Materia de control Sección III

La comisión auditará la protección de los datos personales y de salud tratados por el canal digital de la Clínica Santa Lucía entre el 01/01/2026 y el 30/09/2026. La materia comprenderá acceso, sesiones, transmisión, formularios, configuración y custodia vinculados con esos datos. Se justifica por el resultado ajeno observado el 08/09/2026 y por E4, E6 y E8, que muestran identificadores de resultados, transmisión prevista mediante GET y ausencia de protecciones de sesión. La prioridad será la confidencialidad de la información clínica.

3. Alcance Sección IV

Bloque	Contenido
Incluye	Portal http://127.0.0.1:8080/ con citas (3 850/mes), resultados (12 400 pacientes con cuenta), postulaciones (214 con CV en 2026), administración y exposición de respaldos. Pruebas http://127.0.0.1:8081/: copia productiva anunciada el 12/09; población y anonimización por determinar. API http://127.0.0.1:8088/: citas, pacientes y resultados referidos a las poblaciones del portal, sin asumir que estén íntegramente replicadas. Se revisarán inventario, accesos, configuración y responsabilidades de WebSur vinculadas con los tres activos.
Periodo auditado	01/01/2026 al 30/09/2026, solicitado por Gerencia, que incluye incidente y copia de septiembre. El reconocimiento del 28/10 se contrastará con registros y cambios históricos. Las 214 postulaciones corresponden a 2026 completo: se solicitará corte a 30/09 para fijar la población del periodo.
Excluye expresamente	Auditoría financiera/asistencial, dispositivos médicos, infraestructura física, red interna y LIS, por no ser el canal digital autorizado. No se enviará tráfico a dominios .test, 10.20.0.15 ni producción real. En Unidad II se excluyen formularios enviados, autenticación, descarga de respaldos, /v1/, fuzzing y escaneo activo por falta de autorización. Su ejecución posterior requerirá aprobación escrita. Se excluye analizar operaciones de 2025, pero no la exposición actual del respaldo cuyo nombre contiene ese año.
Limitaciones inherentes	Seguridad razonable, no absoluta. La réplica estática no demuestra autenticación ni acceso real a bases de datos; Unidad III requerirá réplica funcional y datos sintéticos. No hay logs históricos ni población exacta de copias/API; no se concluirá eficacia histórica sin ellos. La muestra dirigida no admite extrapolación estadística. HTTPS 443 queda pendiente de aclaración. La falta de acceso se informará como limitación, sin sustituirla por un resultado favorable.

4. Objetivos Sección V

Objetivo general. Determinar si los controles del canal digital protegieron la confidencialidad, integridad y disponibilidad de los datos durante el periodo auditado, utilizando OWASP WSTG 4.2, OWASP ASVS 4.0.3, NTP-ISO/IEC 27001:2022 y Ley 29733 como criterios de evaluación.

N.º	Objetivo específico	Pregunta de auditoría
OE1	Evaluar autenticación, autorización y separación de sesiones/caché conforme a WSTG-ATHZ-04, WSTG-ATHN-07 y ASVS V4.2.1 y V8.1.1, para determinar si explican o permiten repetir el incidente.	¿Una cuenta puede consultar resultados de otro titular o recuperar de caché información ajena?
OE2	Verificar configuración, inventario, actualización, segregación y protección de administración/respaldos conforme a WSTG-CONF-04 y CONF-05, ASVS V14.2.1 y NTP A.8.8 y A.8.31.	¿Los tres activos y componentes se mantienen inventariados y protegidos frente a acceso no autorizado?
OE3	Determinar la protección de transmisión, cookies y recopilación conforme a WSTG-CRYP-03, WSTG-SESS-02, ASVS V8.3.1 y V8.3.3 y Ley 29733 arts. 9, 13 y 18.	¿Los flujos evitan datos sensibles en claro o URL y acreditan información previa y base habilitante del tratamiento?

5. Enfoque materialidad y riesgo Sección VI

Elemento	Decisión	Sustento
Enfoque	Sustantivo, con inspección documental y pruebas directas en Unidad III.	E1/E7 contradicen inventario y restricciones; E8 muestra protecciones ausentes. No se confiará en declaraciones ni se probará eficacia operativa de un control inexistente.
Materialidad cuantitativa	Umbral de planificación propuesto: 1 % de 12 400 cuentas = 124 cuentas potencialmente afectadas para priorizar extensión y escalamiento.	Base declarada en solicitud. No es tolerancia de divulgación. Se considerarán separadamente 3 850 citas/mes y 214 postulaciones de 2026; las citas no se equipararán con personas únicas ni se inventarán pérdidas monetarias.
Materialidad cualitativa	Una revelación no autorizada de salud será material aunque no haya pérdida económica y afecte a menos de 124 cuentas.	Incidente comunicado; Ley 29733 art. 2.5 sobre datos sensibles y arts. 9/17 sobre seguridad y confidencialidad. Prima sobre el umbral cuantitativo.
Riesgo inherente	Alto.	Salud, identidad, volumen de cuentas e incidente; E6 confirma recopilación de síntomas/especialidad.
Riesgo de control	Alto, preliminar.	E7 muestra listado/interfaz expuestos y E8 cuatro cabeceras ausentes y tres atributos faltantes. Eficacia histórica no probada.
Riesgo de detección	Alto con reconocimiento solo; nivel aceptable objetivo bajo para ejecución posterior.	Réplica estática, ausencia de logs y muestra dirigida pueden ocultar fallos. La comisión lo reducirá con consultas cruzadas sintéticas, examen histórico y cobertura de los tres activos; esa reducción aún no se acredita.

6. Procedimientos Sección VII

La comisión ejecutará seis procedimientos en Unidad III, tras aprobarse el plan y habilitarse una réplica funcional con datos sintéticos. Cubrirán OE1-OE3 y seis categorías WSTG: ATHZ, ATHN, SESS, CRYP, CONF y BUSL. No se ejecutaron durante el reconocimiento. La autorización precisará activos, cuentas, operaciones y puertos; si faltan, se registrará limitación. La estimación será de 22 horas.

P-01 Autorización y caché de resultados

Columna	Contenido
Objetivo específico	OE1. Respuesta directa al incidente del 08/09/2026.
Origen en el reconocimiento	E4: patrón ver.php?orden=NNNNN; E1: API anuncia resultados. Incidente e hipótesis de caché: solicitud.
Riesgo	Consulta de resultados de otro paciente por autorización insuficiente o caché compartida.
Criterio	WSTG-ATHZ-04 · WSTG-ATHN-06 · ASVS 4.0.3 V4.2.1, V8.1.1, V8.2.1 · NTP-ISO/IEC 27001:2022 A.8.3 · Ley 29733 arts. 9 y 17.
Tipo de prueba	Sustantiva de autorización/aislamiento de caché e inspección del incidente.
Población y muestra	Marco: 12 400 cuentas; cantidad de resultados por confirmar. Muestra dirigida: 2 cuentas ficticias A/B, 2 órdenes por cuenta, en portal y API si se habilita. Censo del expediente y logs conservados del incidente, mediante datos disociados.
Procedimiento	Pasos indicados debajo.
Evidencia a obtener	Matriz cuenta-orden-canal, respuestas, cabeceras y marcadores sintéticos; trazabilidad del expediente sin datos clínicos.
Definición de excepción	Una respuesta entrega un resultado de otro titular ficticio, o contenido de A aparece en sesión/caché de B o sin sesión. Falta de expediente: limitación documental, no causa técnica demostrada.
Horas estimadas	5 horas.

Pasos

1. Obtenga autorización escrita para consultas autenticadas y endpoints concretos; confirme aislamiento de producción.

2. Prepare dos cuentas y cuatro resultados sintéticos con titularidad esperada; limite los identificadores a esas cuatro órdenes.

3. Consulte cada orden con su propietario, con la otra cuenta y sin sesión. Registre si la aplicación devuelve contenido ajeno o deniega acceso.

4. Repita en navegadores separados, tras cerrar sesión y con caché habilitada; capture Cache-Control, Vary y marcador visible. Repita en API solo si está habilitada y autorizada.

5. Solicite expediente, análisis causal y logs del incidente; correlacione titularidad, accesos y cambios de caché usando identificadores disociados.

6. Compare con la excepción y declare si se acreditó la causa o sigue indeterminada.

P-02 Credenciales iniciales y recuperación

Columna	Contenido
Objetivo específico	OE1.
Origen en el reconocimiento	E4: contraseña por fecha de nacimiento y cuenta de pruebas anunciada; E6: formularios de acceso.
Riesgo	Suplantación por secretos predecibles o recuperación sin acreditar identidad.
Criterio	WSTG-ATHN-07 · WSTG-ATHN-09 · ASVS 4.0.3 V2.1.1 y V2.5.2 · NTP-ISO/IEC 27001:2022 A.8.5 · Ley 29733 arts. 9 y 17.
Tipo de prueba	Sustantiva funcional e inspección del proceso de alta/recuperación.
Población y muestra	Procesos de pacientes y administración. Dos pacientes ficticios recién registrados y una cuenta administrativa de prueba proporcionada por Sistemas. No se harán intentos masivos sobre las 12 400 cuentas.
Procedimiento	Pasos indicados debajo.
Evidencia a obtener	Política y capturas de alta, cambio obligatorio y recuperación; registro de intentos autorizados con secretos ocultos.
Definición de excepción	Una cuenta admite nacimiento como secreto de ocho caracteres, permite acceso sin sustituir la credencial inicial o recupera acceso sin el mecanismo aprobado de acreditación de identidad.
Horas estimadas	3 horas.

Pasos

1. Solicite política y procesos del periodo; acuerde máximo de un intento por credencial ficticia conocida, sin fuerza bruta.

2. Observe dos altas ficticias y la credencial entregada; compruebe longitud mínima de 12 caracteres de ASVS V2.1.1 y ausencia de fechas públicas como secreto.

3. Compruebe cambio obligatorio antes de ver resultados; no use la cuenta admin_pruebas descubierta ni otras identidades reales.

4. Ejecute recuperación ficticia y compruebe acreditación de identidad. Simule cualquier atención por WhatsApp con la contraparte, sin enviar mensajes a terceros.

5. Revise el acceso administrativo con credenciales suministradas; documente excepciones y restaure las cuentas de prueba.

P-03 Transporte y cookies de sesión

Columna	Contenido
Objetivo específico	OE3.
Origen en el reconocimiento	E8: HTTP, cuatro cabeceras y tres atributos ausentes; E6: cuatro actions HTTP.
Riesgo	Intercepción de datos y uso indebido de sesiones.
Criterio	WSTG-CRYP-03 · WSTG-SESS-02 · ASVS 4.0.3 V9.1.1, V3.4.1, V3.4.2 y V3.4.3 · NTP-ISO/IEC 27001:2022 A.8.24 · Ley 29733 art. 9.
Tipo de prueba	Sustantiva de configuración y transmisión sintética.
Población y muestra	Censo de 3 activos y 4 formularios; cookies de los flujos autorizados de 2 cuentas ficticias. Puertos TLS definidos en nueva autorización.
Procedimiento	Pasos indicados debajo.
Evidencia a obtener	Matriz de transporte, redirecciones, cabeceras y cookies; solicitudes con tokens ocultos.
Definición de excepción	Un flujo sensible usa HTTP; una cookie carece de Secure, HttpOnly o SameSite; o falta una de las cuatro cabeceras sin un control equivalente evaluado y documentado.
Horas estimadas	3 horas.

Pasos

1. Resuelva por escrito el alcance de puertos TLS, incluido 443; no presuma autorización previa.

2. Compruebe redirecciones antes de enviar datos y destinos TLS en los cuatro formularios de la réplica funcional.

3. Complete los flujos permitidos con marcadores ficticios y examine solicitudes en el navegador; oculte tokens al guardar evidencia.

4. Inspeccione los tres atributos de cookies y cuatro cabeceras; evalúe HSTS sobre HTTPS, no solo sobre HTTP.

5. Registre por separado excepciones comprobadas, servicios no disponibles y restricciones de alcance.

P-04 Administración y respaldos

Columna	Contenido
Objetivo específico	OE2.
Origen en el reconocimiento	E3 revela rutas; E7 lista cuatro archivos y /admin/ HTTP 200.
Riesgo	Acceso no autorizado a copias, configuración o funciones privilegiadas.
Criterio	WSTG-CONF-04 · WSTG-CONF-05 · ASVS 4.0.3 V4.3.1, V4.3.2 y V8.1.6 · NTP-ISO/IEC 27001:2022 A.8.3 y A.8.13 · Ley 29733 arts. 9 y 17.
Tipo de prueba	Inspección y prueba sustantiva de restricciones.
Población y muestra	Censo de /admin/, /respaldos/ y los cuatro nombres listados. Una copia señuelo sintética por tipo (.sql.gz, .csv y .bak); no se usarán archivos originales.
Procedimiento	Pasos indicados debajo.
Evidencia a obtener	Reglas de acceso, matriz de roles/redes, respuestas a señuelos y contrato/política de custodia.
Definición de excepción	Un usuario no autorizado obtiene un señuelo, listado sensible o función privilegiada; o la interfaz declarada interna es accesible desde la red externa de prueba. Login visible no demuestra privilegios.
Horas estimadas	3 horas.

Pasos

1. Obtenga permiso de pruebas y cree señuelos sintéticos con Sistemas.
2. Inspeccione raíz web, autoindex, permisos, almacenamiento y responsabilidades contractuales de respaldo/restauración.
3. Compare acceso anónimo y autorizado desde perfiles de red aprobados, sin probar contraseñas desconocidas.
4. Verifique copias fuera de raíz pública, acceso restringido y mecanismo de restauración documentado.
5. Registre excepciones y retire señuelos. No descargue los cuatro archivos originales del reconocimiento.

P-05 Componentes entornos y proveedor

Columna	Contenido
Objetivo específico	OE2.
Origen en el reconocimiento	E1: pruebas con copia y API no inventariadas; E2/E5: versiones antiguas; E4: datos internos.
Riesgo	Componentes sin mantenimiento y copias productivas en entornos insuficientemente protegidos.
Criterio	WSTG-CONF-02 · ASVS 4.0.3 V14.2.1 y V14.2.5 · NTP-ISO/IEC 27001:2022 A.8.8, A.8.31, A.8.33 y A.5.20 · Ley 29733 art. 9.
Tipo de prueba	Inspección sustantiva de inventario, configuración e historial.
Población y muestra	Censo de 3 activos y 7 tecnologías anunciadas: nginx, PHP, WordPress, medicalpro, Contact Form 7, jQuery y wp-file-manager. Nueve registros mensuales enero-septiembre y expediente de copia del 12/09.
Procedimiento	Pasos indicados debajo.
Evidencia a obtener	Inventario/SBOM validado, versiones reales, tickets, análisis CVE, segregación, autorización de copia y contrato.
Definición de excepción	Activo sin responsable/inventario; componente real sin soporte o con CVE aplicable sin tratamiento aprobado; copia productiva en pruebas sin autorización y protección equivalente o anonimización acreditada.
Horas estimadas	4 horas.

Pasos

1. Solicite inventario, SBOM, configuración y contrato; contraste los tres activos y sus responsables.

2. Confirme las siete tecnologías mediante inventario autenticado; diferencie banners simulados de software instalado.

3. Contraste versiones reales con fuentes oficiales y CVE-2020-25213; determine condiciones de aplicabilidad sin exploits.

4. Revise los nueve registros mensuales para evaluar D3; no infiera periodicidad de una versión en URL.

5. Inspeccione separación y expediente de copia del 12/09: autorización, anonimización, protección y eliminación, mediante metadatos/informes sin copiar datos personales.

6. Identifique comentarios internos y responsables de retiro; documente excepciones por activo y periodo acreditado.

P-06 Formularios consentimiento y archivos

Columna	Contenido
Objetivo específico	OE3.
Origen en el reconocimiento	E6: GET con síntomas, casilla acepto y CV. La solicitud declara que la casilla carece de texto.
Riesgo	Datos en URL, tratamiento sin garantías y recepción insegura de archivos.
Criterio	WSTG-BUSL-01 · WSTG-BUSL-08 · ASVS 4.0.3 V8.3.1, V8.3.3 y V12.1.1 · NTP-ISO/IEC 27001:2022 A.5.34 y A.8.26 · Ley 29733 arts. 13.5, 13.6, 14 y 18.
Tipo de prueba	Sustantiva funcional e inspección documental del tratamiento.
Población y muestra	Censo de 4 formularios. Dos citas ficticias (aceptación/no aceptación), una consulta ficticia de resultados y tres postulaciones con archivos inertes (PDF permitido, tipo no permitido y PDF sobre límite acordado). Marco declarado: 3 850 citas/mes, 12 400 cuentas y 214 postulaciones en 2026. Muestra dirigida sin extrapolación.
Procedimiento	Pasos indicados debajo.
Evidencia a obtener	Matriz campos-finalidad-base habilitante, aviso, registro de consentimiento cuando proceda y decisiones de validación de CV.
Definición de excepción	DNI, síntomas, contraseña o token en URL; recopilación sin información del art. 18; falta de consentimiento exigible sin excepción legal acreditada; aceptación de archivo contrario a tipo/tamaño previamente aprobados.
Horas estimadas	4 horas.

Pasos

1. Obtenga autorización de envíos en réplica funcional y política previa de tipos/tamaño. Use identidades ficticias y archivos inertes, sin código activo.

2. Relacione campos con finalidad, obligatoriedad, conservación y destinatarios; solicite aviso y base habilitante por tratamiento.

3. Revise información previa del art. 18 y consentimiento cuando proceda según arts. 13.5/13.6; evalúe excepciones pertinentes del art. 14. No presuma que consentimiento sea la única base para toda atención sanitaria.

4. Ejecute citas y consulta ficticias; revise URL, historial y registros sin conservar valores personales.

5. Envíe los tres CV inertes autorizados; compare decisiones con la política fijada antes de probar y revise permisos/ubicación del aceptado.

6. Documente excepciones por formulario y elimine datos ficticios dejando constancia.

7. Anexo A Matriz de riesgos

N.º	Riesgo	Causa con evidencia	Impacto	Nivel	Control existente observado	Control esperado
R1	Resultados ajenos.	E4: orden y contraseña predecible. Incidente según solicitud; IDOR/caché son hipótesis.	Revelación de salud.	Alto	E6: formulario DNI/clave; eficacia no probada.	Autorización por titular, aislamiento de caché y secretos robustos; P-01/P-02.
R2	Copias o administración expuestas.	E7: cuatro archivos y /admin/ visible; E3 revela rutas.	Exposición masiva o privilegios indebidos.	Alto	Login visible; restricción interna declarada no observada.	Copias fuera de raíz pública, sin autoindex, restricciones y MFA; P-04.
R3	Intercepción o uso indebido de sesión.	E8: cuatro cabeceras y tres atributos ausentes; E6: HTTP.	Divulgación y suplantación.	Alto	Cookie con path=/; HTTP sin redirección; HTTPS no determinado.	TLS y cookies Secure/HttpOnly/SameSite; P-03.
R4	Componentes antiguos y pruebas inseguras.	E1: copia anunciada y tres activos; E2/E5: versiones antiguas.	Exposición, alteración o ind isponibilidad.	Alto	Etiqueta visual de pruebas; inventario/anonimización no acreditados.	Inventario, parches, responsables, segregación y datos protegidos; P-05.
R5	Tratamiento o CV sin garantías.	E6: GET con síntomas, casilla y archivo. Falta de texto según solicitud, pendiente de corroboración funcional.	Divulgación en URL e incumplimiento de derechos.	Alto	Casilla/campos; no acreditan información ni validación.	Datos fuera de URL, aviso/base jurídica y validación de archivos; P-06.

Los niveles serán preliminares: revelar salud, comprometer privilegios o exponer copias supone impacto severo. No se asigna probabilidad numérica ni se afirma explotación confirmada.

Fuentes y criterios consultados

- Documentos originales en documentos/ y evidencias E1-E8 del 28/10/2026.

- OWASP WSTG 4.2.

- OWASP ASVS 4.0.3, capítulos V2, V3, V4, V8, V9, V12 y V14.

- PHP Unsupported Branches: PHP 7.4 terminó soporte el 28/11/2022.

- nginx descargas y archivo oficial 2022: 1.20 legado; estable 1.22.0 publicada el 24/05/2022. Sustitución de rama no equivale a fecha contractual de EOL.

- NVD CVE-2020-25213: File Manager anterior a 6.9; aplicabilidad pendiente de verificar.

- INACAL NTP-ISO/IEC 27001:2022. Se utilizará como criterio técnico; no se presume certificación ni deber general de certificarse para la clínica privada.

- Congreso Ley 29733. La comisión comprobará vigencia y excepciones aplicables antes de concluir incumplimiento jurídico.

Elaborado por: Sergio Colque Ponce · **Código:** 2022073503 · **Fecha:** 28/10/2026